Anthropic

(Claude Certified Architect Professional (CCAR-P))

Claude Certified Architect Professional

Total: **126 Questions**

Link: https://certyiq.com/papers/anthropic/ccar-p

Question: 1 CertyIQ

You are compiling guardrail tactics for a customer-facing assistant.
Which two tactics belong on the guardrail list?
Each correct answer presents a complete solution.

A. Embed approved override phrases that let trusted users relax guardrails on demand.
B. Lower sampling temperature globally to reduce the chance of off-policy completions.
C. Rely on a single hardened system prompt that enumerates every disallowed behavior.
D. Layer prompt-level guardrails with runtime content checks rather than relying on either alone.
E. Validate the model output against a structured schema before downstream actions are taken.

Answer: DE

Explanation:

A. Embed approved override phrases that let trusted users relax guardrails on demand.

Incorrect

Allowing users to bypass guardrails through special phrases can create a **security and policy risk**. Guardrails should not be easily disabled through conversational instructions, even for trusted users.

B. Lower sampling temperature globally to reduce the chance of off-policy completions.

Incorrect

Lowering temperature can make outputs more **consistent and predictable**, but it is not a reliable substitute for explicit safety controls. Model randomness settings alone cannot enforce policy boundaries.

C. Rely on a single hardened system prompt that enumerates every disallowed behavior.

Incorrect

A system prompt is an important layer, but relying on **one control alone** is not sufficient. Complex customer-facing systems benefit from multiple independent safeguards.

D. Layer prompt-level guardrails with runtime content checks rather than relying on either alone.

Correct

Using multiple guardrail layers provides **defense in depth**. Prompt-level instructions establish behavioral boundaries, while runtime checks can detect or block problematic content before it reaches users or downstream systems.

E. Validate the model output against a structured schema before downstream actions are taken.

Correct

Structured output validation helps ensure that the model response conforms to the **expected format and required fields** before it is passed to downstream systems. This reduces the risk of malformed or unexpected model output triggering unintended actions.

Final Answer: D and E

Question: 2 CertyIQ

A Claude architect is implementing safety controls for a customer-facing advice assistant that must never provide regulated investment recommendations.
Which two guardrail implementations most directly enforce this constraint? (Select two.)

A. Increase response temperature to introduce variability that reduces the likelihood of specific recommendations.

B. Log all user queries to a SIEM for post-hoc compliance review.

C. Limit session length to reduce the volume of queries processed per user per day.

D. Define explicit out-of-scope categories in the system prompt with fixed refusal phrasing for investment advicerequests.

E. Add an output classifier that detects and blocks responses containing regulated investment-recommendation language.

Answer: DE

Explanation:

A. Increase response temperature to introduce variability that reduces the likelihood of specific recommendations.

Incorrect

Increasing temperature makes responses **more variable and less predictable**. It does not enforce a safety boundary and could actually make it harder to consistently prevent prohibited investment recommendations.

B. Log all user queries to a SIEM for post-hoc compliance review.

Incorrect

Logging supports **monitoring, auditing, and investigation**, but it is a post-hoc control. It does not directly prevent the assistant from generating a prohibited investment recommendation before the response reaches the user.

C. Limit session length to reduce the volume of queries processed per user per day.

Incorrect

Limiting session length may reduce overall usage, but it does not prevent the model from providing a **regulated investment recommendation within an allowed session**. It is therefore not a direct enforcement mechanism for this requirement.

D. Define explicit out-of-scope categories in the system prompt with fixed refusal phrasing for investment advice requests.

Correct

Explicitly defining **out-of-scope behavior** in the system instructions establishes a clear boundary for the assistant. Fixed refusal guidance also makes the expected response more consistent when users request prohibited investment recommendations.

E. Add an output classifier that detects and blocks responses containing regulated investment-recommendation language.

Correct

An **output classifier** provides a runtime enforcement layer that can detect prohibited content before it

reaches the customer. This complements prompt-level guardrails and provides an additional control if the model attempts to generate restricted advice.

Final Answer: D and E

Question: 3 CertyIQ

You are configuring tool permissions for a Claude-based assistant. The assistant's defined responsibilities require read access to a knowledge base and write access to a draft queue, and nothing else.
Which scoping design best applies least privilege?

A. Allow access to every tool in the catalog and rely on the model to decline tools it should not use.

B. Per-role allow-list of exactly the read-knowledge-base and write-draft-queue tools, enforced at the orchestration layer.

C. Disable all tools entirely to achieve a minimal permission surface, accepting that the assistant can no longer perform the read-knowledge-base or write-draft-queue tasks it was designed for.

D. Allow access to all tools with read permissions globally and restrict write permissions to the draft- queue tool, without scoping to only the specific tools required for defined tasks.

Answer: B

Explanation:

A. Allow access to every tool in the catalog and rely on the model to decline tools it should not use.

Incorrect

This does not follow the **least-privilege principle** because the assistant receives access to tools it does not need. Relying on the model to voluntarily avoid those tools is not an adequate security control.

B. Per-role allow-list of exactly the read-knowledge-base and write-draft-queue tools, enforced at the orchestration layer.

Correct

This is the strongest least-privilege design. The assistant receives access to **only the two tools required for its defined responsibilities**. Enforcing the allow-list at the orchestration layer provides a technical permission boundary rather than relying on the model's behavior.

C. Disable all tools entirely to achieve a minimal permission surface, accepting that the assistant can no longer perform the read-knowledge-base or write-draft-queue tasks it was designed for.

Incorrect

Although disabling all tools minimizes permissions, it also prevents the assistant from performing its **required responsibilities**. Least privilege means granting the minimum permissions necessary to accomplish the intended task, not removing necessary access.

D. Allow access to all tools with read permissions globally and restrict write permissions to the draft-queue tool, without scoping to only the specific tools required for defined tasks.

Incorrect

This still grants **unnecessary access** to tools outside the assistant's responsibilities. Least privilege requires permissions to be scoped to the specific capabilities the assistant actually needs.

Final Answer: B. Per-role allow-list of exactly the read-knowledge-base and write-draft-queue tools, enforced at the orchestration layer.

Question: 4 CertyIQ

You are compiling team-setup practices for a Claude Code rollout across an engineering organization.
Which two practices belong on the list? (Select two.)
Each correct answer presents a complete solution.

A. Use project scope for personal editor preferences so the preferences apply consistently within the project.

B. Apply managed configuration centrally for security-critical settings that must not be overridden by individual engineers.

C. Use local scope for security-critical permission rules so each engineer can adapt them to ongoing work.

D. Use user scope for team-shared MCP servers so every engineer on the team has consistent access.

E. Use project scope for team-shared Model Context Protocol (MCP) servers and permission rules under version control.

Answer: BE

Explanation:

A. Use project scope for personal editor preferences so the preferences apply consistently within the project.

Incorrect

Project scope is intended for **team-shared configuration**, not personal preferences. Personal editor preferences should generally remain at the **user or local scope** so they do not affect other engineers working on the project.

B. Apply managed configuration centrally for security-critical settings that must not be overridden by individual engineers.

Correct

Managed configuration is appropriate for **security-critical controls** that need consistent enforcement across the organization. Central management prevents individual engineers from overriding important security policies.

C. Use local scope for security-critical permission rules so each engineer can adapt them to ongoing work.

Incorrect

Security-critical permission rules should not be individually adjustable when organizational consistency is required. Local configuration could allow engineers to **weaken or bypass important security controls**.

D. Use user scope for team-shared MCP servers so every engineer on the team has consistent access.

Incorrect

User scope applies to an **individual engineer**, not the entire project team. Team-shared MCP servers should be configured at a shared project or managed organizational level.

E. Use project scope for team-shared Model Context Protocol (MCP) servers and permission rules under version control.

Correct

Project scope is appropriate for **team-shared configuration**. Keeping MCP server settings and permission rules under version control improves consistency, reviewability, and change tracking across the engineering organization.

Final Answer: B and E

Question: 5 CertyIQ

You are designing a content moderation classifier that processes high volumes of user-generated comments under a tight per-message latency budget using well-defined classification labels.
Which model selection best aligns with the workload?

A. Sonnet, because larger general-purpose models are preferred even when workload latency requirements are strict.

B. Haiku, because its latency and cost profile align with high-volume classification workloads that require limited reasoning depth.

C. Sonnet with extended thinking enabled, because deeper reasoning should be applied to every moderation request to improve edge-case handling.

D. Opus, because every moderation decision requires maximum reasoning depth regardless of classification complexity.

Answer: B

Explanation:

A. Sonnet, because larger general-purpose models are preferred even when workload latency requirements are strict.

Incorrect

Sonnet provides strong general-purpose capabilities, but this workload emphasizes **high volume, low latency, and well-defined classification tasks**. A lighter model is generally a better fit when deep reasoning is not required.

B. Haiku, because its latency and cost profile align with high-volume classification workloads that require limited reasoning depth.

Correct

Haiku is well suited to **fast, high-volume workloads** where the task is clearly defined and does not require extensive reasoning. Its efficiency helps meet strict latency requirements while controlling resource consumption.

C. Sonnet with extended thinking enabled, because deeper reasoning should be applied to every moderation request to improve edge-case handling.

Incorrect

Extended Thinking adds deeper reasoning but can increase **latency and resource consumption**. Applying it to every high-volume classification request is unnecessary when the labels and task are already well defined.

D. Opus, because every moderation decision requires maximum reasoning depth regardless of classification complexity.

Incorrect

Maximum reasoning capability is not required for every moderation task. Using a highly capable model for simple, high-volume classification can result in **unnecessary cost and latency**.

Final Answer: B. Haiku, because its latency and cost profile align with high-volume classification workloads that require limited reasoning depth.

Question: 6 CertyIQ

You are supporting an engineer whose Claude Code session reports a permission denial when the engineer expected the action to be allowed.
Which resolution step is most appropriate?

A. Inspect the active permission rules across all scopes-managed, command-line, local, project, and user-to identify which rule is denying the action and confirm whether it should be amended or remain denied.

B. Tell the engineer to retry the denied action verbatim repeatedly until the denial stops appearing, without inspecting the active permission rules to determine whether the denial is intentional.

C. Disable the permission system entirely across all scopes to remove the denial, eliminating all tool-pattern and deny-rule controls rather than identifying and amending the specific rule.

D. Grant the engineer unrestricted Bash access to bypass the specific rule causing the denial, removing all tool-pattern constraints rather than amending only the rule in

Answer: A

Explanation:

A. Inspect the active permission rules across all scopes — managed, command-line, local, project, and user — to identify which rule is denying the action and confirm whether it should be amended or remain denied.

Correct

The appropriate approach is to **diagnose the active permission configuration** rather than bypassing the security controls. Reviewing the applicable rules across scopes helps identify the exact rule responsible for the denial and determine whether the rule is intentional or needs to be changed.

B. Tell the engineer to retry the denied action verbatim repeatedly until the denial stops appearing, without inspecting the active permission rules to determine whether the denial is intentional.

Incorrect

Repeated retries do not address the underlying permission configuration. The denial may be intentional, so the correct approach is to **inspect and understand the active rules first**.

C. Disable the permission system entirely across all scopes to remove the denial, eliminating all tool-pattern and deny-rule controls rather than identifying and amending the specific rule.

Incorrect

Disabling the permission system removes important **security controls** and violates the principle of least privilege. Only the specific rule that is incorrectly denying the required action should be considered for amendment.

D. Grant the engineer unrestricted Bash access to bypass the specific rule causing the denial, removing all tool-pattern constraints rather than amending only the rule in question.

Incorrect

Unrestricted Bash access creates an unnecessarily broad **security exposure**. The appropriate solution is to identify and adjust the specific permission rule if necessary, rather than granting unrestricted capabilities.

Final Answer: A. Inspect the active permission rules across all applicable scopes to identify and resolve the specific denial.

Question: 7 CertyIQ

A managed agent deployment for claims triage has grown from 6 tools to 34 tools over 18 months as product teams added capabilities. Triage accuracy has declined from 91 percent to 78 percent, and average tool- selection latency has increased by 2.3 seconds. A junior engineer has proposed adding a tool-router agent in front of the current agent to filter the tool list per request.
Which two findings should you present to justify capability decomposition before adding the router? (Select two.)
Each correct answer presents part of the solution.

A. Tool descriptions overlap across multiple claim categories within the agent's tool set.
B. Several tools have not been invoked across the most recent 90 days of traffic.
C. The router pattern is well documented across publicly available agent literature.
D. The proposed router introduces an additional model call on every incoming request.
E. The 34 tools serve four distinct claim-workflow domains within the triage scope.

Answer: DE

Explanation:

A. Tool descriptions overlap across multiple claim categories within the agent's tool set.

Incorrect

Overlapping tool descriptions can contribute to tool-selection confusion, but this finding alone does not directly establish that the agent should first be **decomposed into separate capability domains**.

B. Several tools have not been invoked across the most recent 90 days of traffic.

Incorrect

Unused tools are useful evidence for **tool rationalization or removal**, but they do not directly demonstrate that the 34-tool set should be divided into separate capability domains.

C. The router pattern is well documented across publicly available agent literature.

Incorrect

The existence of a documented routing pattern does not establish that it is the right architectural solution for this deployment. The team should first understand the **underlying capability structure and performance problem**.

D. The proposed router introduces an additional model call on every incoming request.

Correct

Adding another agent introduces **additional model-call overhead**, which can increase latency and complexity. Since the existing system already has a 2.3-second increase in tool-selection latency, adding another model call may worsen the problem rather than address its root cause.

E. The 34 tools serve four distinct claim-workflow domains within the triage scope.

Correct

This is strong evidence for **capability decomposition**. If the tools naturally fall into four distinct workflow domains, the system can potentially be divided into more focused agents or capability groups, reducing the number of tools each agent must reason over.

Final Answer: D and E

Question: 8 CertyIQ

A technical team is debating whether to implement a new capability for generating regulatory filings from internal data as a Claude Skill or as an MCP server. The capability requires a fixed authoring procedure with embedded examples, does not need to call live external systems, and must be portable across three Claude deployments: claude.ai, an internal API integration, and Claude Code.
Which factor most strongly favors implementing the capability as a Skill?

A. The capability needs to query a live database for the most recent regulatory filings.
B. The capability requires direct authentication against the corporate identity provider.
C. The capability is procedural knowledge with no live external-system calls required.
D. The capability must also be callable from a developer's command-line interface.

Answer: C

Explanation:

A. The capability needs to query a live database for the most recent regulatory filings.

Incorrect

A capability that needs to interact with a **live external system** is better suited to an MCP-based integration. MCP is designed to connect Claude with external tools, services, and data sources.

B. The capability requires direct authentication against the corporate identity provider.

Incorrect

Direct authentication and integration with enterprise systems are characteristics that favor an **MCP server or another external integration**, rather than a Skill focused on procedural knowledge.

C. The capability is procedural knowledge with no live external-system calls required.

Correct

This is the strongest reason to choose a **Skill**. Skills are well suited to reusable **procedures, instructions, examples, and domain-specific workflows** that Claude can apply when relevant. Since this capability does not need to call live external systems, an MCP server is unnecessary.

D. The capability must also be callable from a developer's command-line interface.

Incorrect

Being usable from Claude Code does not by itself make MCP the better choice. The key distinction is whether the capability primarily provides **procedural knowledge** or requires **external tools and system access**.

Final Answer: C. The capability is procedural knowledge with no live external-system calls

Question: 9 CertyIQ

A Claude architect is auditing configuration scope assignments.
Which two statements correctly identify an appropriate use of user-scope configuration versus other scopes? (Select two.)

A. Defining MCP server endpoints shared by all contributors to a specific repository.
B. Storing API authentication keys so they are not committed to version control.
C. Enforcing a company-wide policy that disables a feature for all engineers.
D. Persisting personal editor theme preferences that follow an engineer across projects.
E. Saving a preferred Claude response language that applies to all repositories the engineer uses.

Answer: DE

Explanation:

A. Defining MCP server endpoints shared by all contributors to a specific repository.

Incorrect

MCP servers shared by contributors to a particular repository are better suited to **project scope**, because project-level configuration can be shared and maintained with the project rather than tied to one individual engineer.

B. Storing API authentication keys so they are not committed to version control.

Incorrect

Authentication keys and other secrets require **secure secret-management practices**. Simply placing them in user-scope configuration is not the appropriate general solution for protecting sensitive credentials.

C. Enforcing a company-wide policy that disables a feature for all engineers.

Incorrect

Company-wide security or policy requirements should be enforced through **managed/organizational configuration**, rather than user scope. Individual engineers should not be able to override centrally required controls.

D. Persisting personal editor theme preferences that follow an engineer across projects.

Correct

User scope is appropriate for **personal preferences** that should follow an individual engineer across different projects. An editor theme is a good example because it does not need to be shared with the entire team.

E. Saving a preferred Claude response language that applies to all repositories the engineer uses.

Correct

A preferred response language is also an **individual user preference**. User scope allows the preference to persist across the engineer's different repositories and projects without imposing it on other team members.

Final Answer: D and E

Question: 10 CertyIQ

A research summarization assistant has been deployed for six months. A user has flagged that a generated summary contained a fabricated citation. The product team has asked whether the incident requires architectural action or whether it is an isolated case.
Which two Diligence-competency actions should you take? (Select two.)
Each correct answer presents part of the solution.

A. Disable the assistant immediately for all current users without any prior diagnostic analysis.
B. Review whether citation-grounding controls exist anywhere in the current generation pipeline.
C. Sample recent summaries to estimate the fabrication frequency across the population.
D. Treat the incident as an anecdotal isolated case and take no further investigative action.
E. Communicate to users that the assistant does not fabricate output as a matter of design.

Answer: BC

Explanation:

A. Disable the assistant immediately for all current users without any prior diagnostic analysis.

Incorrect

Immediately disabling the assistant may be appropriate in an extreme safety situation, but this scenario first requires **evidence-based investigation**. The team needs to understand the scope and cause of the issue before deciding on an architectural response.

B. Review whether citation-grounding controls exist anywhere in the current generation pipeline.

Correct

Reviewing the existing pipeline determines whether there are **controls designed to prevent unsupported or fabricated citations**. This helps identify potential architectural weaknesses and whether additional grounding or validation mechanisms are needed.

C. Sample recent summaries to estimate the fabrication frequency across the population.

Correct

Sampling recent outputs helps determine whether the reported citation is an **isolated event or part of a recurring pattern**. Measuring the frequency provides evidence for deciding whether broader corrective or architectural action is warranted.

D. Treat the incident as an anecdotal isolated case and take no further investigative action.

Incorrect

A single reported incident should not automatically be dismissed. Diligence requires **investigating and assessing the broader risk** before concluding that the problem is isolated.

E. Communicate to users that the assistant does not fabricate output as a matter of design.

Incorrect

A design intention does not prove that the system cannot produce fabricated content. Such a statement could create a **false sense of reliability** rather than addressing the reported incident.

Final Answer: B and C

Question: 11 CertyIQ

A customer support team has proposed delegating customer refund decisions to a Claude-driven workflow with no human review for refunds under 50 USD. The team's reasoning is that small refunds are low-risk and human review would erase the efficiency gain.
Which Delegation-competency principle should quide your response?

A. Delegation should be avoided entirely wherever financial transactions occur in the workflow.
B. Delegation should always include human review on every decision the workflow produces.
C. Delegation scope should reflect the type of risk involved, not the transaction size alone.
D. Delegation scope should be set primarily by maximizing efficiency gains across the workflow.

Answer: C

Explanation:

A. Delegation should be avoided entirely wherever financial transactions occur in the workflow.

Incorrect

Delegation is not automatically inappropriate simply because a workflow involves financial transactions. The appropriate approach is to assess the **specific risks and consequences** and determine what level of human oversight is necessary.

B. Delegation should always include human review on every decision the workflow produces.

Incorrect

Human review is important for higher-risk decisions, but requiring manual review for **every single decision** is unnecessarily rigid. Appropriate delegation depends on the risk associated with the task and its potential impact.

C. Delegation scope should reflect the type of risk involved, not the transaction size alone.

Correct

The **risk associated with an action** is more important than the dollar amount alone. Even a small refund could involve fraud, customer disputes, policy exceptions, or other consequences. Delegation should therefore consider factors such as **financial, legal, customer, and reputational risk** when determining the appropriate level of human oversight.

D. Delegation scope should be set primarily by maximizing efficiency gains across the workflow.

Incorrect

Efficiency is an important consideration, but it should not override **risk management and accountability**. Delegation decisions should balance productivity with the potential consequences of automated decisions.

Final Answer: C. Delegation scope should reflect the type of risk involved, not the transaction size alone.

Question: 12 CertyIQ

You must present an architectural recommendation to deploy a Claude-based contract review assistant to a steering committee that includes the CFO, the general counsel, and the CIO. Each stakeholder cares about

different aspects of the decision.
How should you structure the recommendation document?

A. Lead with detailed cost projections across the full multi-year horizon before the rationale section.
B. Lead with the technical architecture diagram and the full component list before any other section.
C. Present the same dense narrative throughout with no stakeholder differentiation in any section.
D. Lead with the architectural decision, then address each stakeholder's primary concerns directly.

Answer: D

Explanation:

A. Lead with detailed cost projections across the full multi-year horizon before the rationale section.

Incorrect

Cost is highly relevant to the CFO, but leading exclusively with detailed financial projections may not address the **legal, technical, and strategic concerns** of the other stakeholders.

B. Lead with the technical architecture diagram and the full component list before any other section.

Incorrect

The technical architecture is particularly important to the CIO, but beginning with a detailed component list may overwhelm stakeholders who primarily need to understand the **decision, rationale, risks, and business impact**.

C. Present the same dense narrative throughout with no stakeholder differentiation in any section.

Incorrect

Different stakeholders have different responsibilities and concerns. A one-size-fits-all narrative may fail to address the **specific information each decision-maker needs**.

D. Lead with the architectural decision, then address each stakeholder's primary concerns directly.

Correct

The strongest approach is to **state the recommendation clearly at the beginning** and then address the key concerns of each stakeholder. For example, the CFO may focus on cost and ROI, the General Counsel on legal risk and compliance, and the CIO on architecture, security, integration, and operational considerations.

This structure makes the recommendation **decision-oriented, concise, and relevant to the entire steering committee**.

Final Answer: D. Lead with the architectural decision, then address each stakeholder's primary concerns directly.

Question: 13 CertyIQ

You are investigating an MCP server that fails on first launch but succeeds on subsequent runs. System permission dialogs appeared during the first launch.
Which response is most appropriate?

A. Treat the first-run failure as a permanent fault, replace the MCP server, and do not verify whether subsequent runs succeed.

B. Reinstall the operating system to clear all permission state without first confirming whether the one- time permission grant caused the failure.

C. Recognize the first-run permission grant as the cause, document the expected behavior in onboarding guidance, and confirm that subsequent runs succeed.

D. Disable operating-system permission dialogs entirely, accept the resulting security implications, and proceed without confirming whether the failure recurs.

Answer: C

Explanation:

A. Treat the first-run failure as a permanent fault, replace the MCP server, and do not verify whether subsequent runs succeed.

Incorrect

The fact that the MCP server succeeds on subsequent runs strongly suggests that the initial failure may be related to **first-run permissions or authorization**. Replacing the server without investigating would be unnecessary and could fail to address the actual cause.

B. Reinstall the operating system to clear all permission state without first confirming whether the one-time permission grant caused the failure.

Incorrect

Reinstalling the operating system is an **extreme and unnecessary troubleshooting step**. The permission dialogs provide a much more relevant clue that should be investigated first.

C. Recognize the first-run permission grant as the cause, document the expected behavior in onboarding guidance, and confirm that subsequent runs succeed.

Correct

The appearance of system permission dialogs during the first launch is a strong indication that the initial failure was related to **one-time operating-system authorization**. The appropriate response is to document this expected first-run behavior and verify that the MCP server works normally afterward.

D. Disable operating-system permission dialogs entirely, accept the resulting security implications, and proceed without confirming whether the failure recurs.

Incorrect

Disabling operating-system permission controls unnecessarily weakens **security protections**. The better approach is to understand the permission requirement, document it, and verify successful subsequent operation.

Final Answer: C. Recognize the first-run permission grant as the cause, document the expected behavior in onboarding guidance, and confirm that subsequent runs succeed.

Question: 14 CertyIQ

You are producing an architecture guide for a new deployment and must complete the planning steps before drafting each section.
Which two steps must be completed BEFORE drafting each section of the guide? (Select two.) Each correct answer presents part of the solution.

A. Translate the guide into the supported regional languages for the candidate population.
B. Establish the document under version control with a defined review cadence and approver list.
C. Identify the audience and the questions the guide must answer for that audience.
D. Outline the guide sections covering the overview, components, contracts, flows, runbooks, and limitations.
E. Validate the guide with the implementation team and incorporate corrections.

Answer: CD

Explanation:

A. Translate the guide into the supported regional languages for the candidate population.

Incorrect

Translation is a later-stage activity. Before drafting, the priority is to establish **who the guide is for and what information it needs to contain**.

B. Establish the document under version control with a defined review cadence and approver list.

Incorrect

Version control, review cadence, and approval processes are valuable for document governance, but they are not the primary **content-planning steps** required before drafting the sections.

C. Identify the audience and the questions the guide must answer for that audience.

Correct

Before writing, you should understand the **intended audience and their information needs**. This ensures that each section is written at the appropriate technical level and addresses the questions stakeholders actually need answered.

D. Outline the guide sections covering the overview, components, contracts, flows, runbooks, and limitations.

Correct

Creating an outline establishes the guide's **structure and scope** before detailed writing begins. It helps ensure important architecture topics are covered systematically and prevents unnecessary duplication or omissions.

E. Validate the guide with the implementation team and incorporate corrections.

Incorrect

Validation with the implementation team is an important **review and refinement step**, but it happens after the relevant content has been drafted rather than before drafting each section.

Final Answer: C and D

Question: 15 CertyIQ

You are responding to an adversarial input pattern in which users include text claiming admin authority and instructing the model to bypass safety restrictions.
Which combination of controls most effectively mitigates this attack pattern?

A. Prompt-level instructions that treat user content as untrusted data, runtime classifiers that detect override attempts, scoped tool permissions that cannot be elevated by user content, and audit logging of attempts.

B. Granting users any privilege level they assert in their message content, on the assumption that cooperative behavior requires honoring self-declared authority without independent verification.

C. Trusting that the model will intrinsically recognize and reject all bypass attempts without prompt-level instructions, runtime classifiers, scoped permissions, or audit logging.

D. Removing all safety restrictions and guardrails to eliminate the attack surface that bypass attempts target, accepting that this makes the assistant unrestricted for all inputs.

Answer: A

Explanation:

A. Prompt-level instructions that treat user content as untrusted data, runtime classifiers that detect override attempts, scoped tool permissions that cannot be elevated by user content, and audit logging of attempts.

Correct

This approach provides **defense in depth**. User-provided claims of authority are treated as untrusted input, runtime controls can identify suspicious override attempts, and scoped permissions prevent the user from escalating privileges simply through prompt content. Audit logging also supports **monitoring, investigation, and incident response**.

B. Granting users any privilege level they assert in their message content, on the assumption that cooperative behavior requires honoring self-declared authority without independent verification.

Incorrect

User-supplied text is not a reliable source of authorization. Allowing users to declare their own privileges creates a serious **privilege-escalation risk**.

C. Trusting that the model will intrinsically recognize and reject all bypass attempts without prompt-level instructions, runtime classifiers, scoped permissions, or audit logging.

Incorrect

A model should not be treated as the **sole security boundary**. Multiple technical and procedural controls are needed because adversarial inputs can sometimes bypass model-level instructions.

D. Removing all safety restrictions and guardrails to eliminate the attack surface that bypass attempts target, accepting that this makes the assistant unrestricted for all inputs.

Incorrect

Removing safety controls does not mitigate the attack; it **eliminates the protections** that are intended to prevent unsafe behavior.

Final Answer: A. Use layered prompt, runtime, permission, and audit controls.

Question: 16 CertyIQ

You are a solution architect designing a Claude-based assistant with access to 60 internal tools across multiple business domains. Loading every tool definition on every request increases token usage and time to first response. Which design pattern best addresses this issue without sacrificing capability breadth?

A. Increase the maximum context length and load all 60 tool definitions on every request, accepting the higher token cost and latency as necessary for full capability.

B. Apply progressive tool discovery so a curated initial subset is exposed and additional tools are loaded on demand based on the task.

C. Hard-code a fixed set of five tools per request to reduce token usage, regardless of whether those tools are relevant to the current task.

D. Use a separate model call to summarize all 60 tool definitions before each user turn.

Answer: B

Explanation:

A. Increase the maximum context length and load all 60 tool definitions on every request, accepting the higher token cost and latency as necessary for full capability.

Incorrect

Increasing context capacity does not solve the underlying efficiency problem. Loading all 60 tool definitions on every request still consumes **tokens and processing time**, even when most tools are irrelevant to the current task.

B. Apply progressive tool discovery so a curated initial subset is exposed and additional tools are loaded on demand based on the task.

Correct

Progressive tool discovery reduces the amount of tool information that must be loaded initially. A relevant subset can be exposed first, and additional tools can be discovered or loaded when the task requires them. This preserves broad capability while reducing **initial token usage and latency**.

C. Hard-code a fixed set of five tools per request to reduce token usage, regardless of whether those tools are relevant to the current task.

Incorrect

Although this reduces token usage, it can **restrict capability** and prevent Claude from accessing tools required for a particular request. The selection should be task-relevant rather than an arbitrary fixed number.

D. Use a separate model call to summarize all 60 tool definitions before each user turn.

Incorrect

This adds another model call and therefore introduces **additional latency and resource consumption**. It also does not necessarily provide Claude with the precise tool definitions needed for reliable tool use.

Final Answer: B. Apply progressive tool discovery so relevant tools are exposed initially and additional tools are loaded on demand.

Question: 17 CertyIQ

You are presenting an architectural decision to a mixed audience that includes an executive sponsor and the engineering leads who will implement the decision.
Which presentation strategy best serves both audiences?

A. Open with a deep dive into low-level implementation details targeted at engineering leads, and stop there without addressing the business outcomes or trade-offs the executive sponsor needs.

B. Skip the rationale, alternatives, and trade-off discussion entirely and simply announce the chosen decision, leaving both audiences without the context needed to implement or validate it.

C. Lead with the decision, the business outcomes it serves, and the trade-offs accepted; follow with the technical rationale, alternatives, and implementation implications for the engineering audience.

D. Present a single undifferentiated narrative that addresses technical and business concerns with equal weight throughout, treating both audiences as requiring the same depth on every section.

Answer: C

Explanation:

A. Open with a deep dive into low-level implementation details targeted at engineering leads, and stop there without addressing the business outcomes or trade-offs the executive sponsor needs.

Incorrect

This approach focuses almost entirely on the engineering audience and fails to address the executive sponsor's need to understand **business outcomes, strategic rationale, risks, and trade-offs**.

B. Skip the rationale, alternatives, and trade-off discussion entirely and simply announce the chosen decision, leaving both audiences without the context needed to implement or validate it.

Incorrect

Simply announcing the decision does not provide enough context. Both audiences need to understand **why the decision was made**, what alternatives were considered, and what trade-offs were accepted.

C. Lead with the decision, the business outcomes it serves, and the trade-offs accepted; follow with the technical rationale, alternatives, and implementation implications for the engineering audience.

Correct

This structure serves both audiences effectively. Executives get the **decision, business value, and key trade-offs early**, while engineering leads receive the **technical rationale, alternatives, and implementation details** needed to execute the decision.

D. Present a single undifferentiated narrative that addresses technical and business concerns with equal weight throughout, treating both audiences as requiring the same depth on every section.

Incorrect

Different stakeholders have different information needs. Giving every section equal technical and business depth can make the presentation **less focused and less useful** for both audiences.

Final Answer: C. Lead with the decision, business outcomes, and trade-offs, followed by the technical rationale and implementation implications.

Question: 18 CertyIQ

You are designing a test strategy for a Claude-based pipeline that handles sensitive financial data. hich two test types should be prioritized to cover both safety under attack and cross-component correctness?
(Select two.)

A. Integration tests that verify end-to-end pipeline behavior across all components.

B. Smoke tests that verify core paths after each deployment.

C. Unit tests targeting only individual prompt-template rendering logic.

D. Regression tests against a stable reference set of previously known-good outputs.

E. Adversarial tests using prompt-injection and malformed-input cases.

Answer: AE

Explanation:

A. Integration tests that verify end-to-end pipeline behavior across all components.

Correct

Integration tests verify that the different components of the pipeline work correctly **together**. For a sensitive financial-data workflow, this is important because failures can occur at the boundaries between components even when individual components work correctly in isolation.

B. Smoke tests that verify core paths after each deployment.

Incorrect

Smoke tests are useful for quickly checking whether the system's **basic functionality** works after deployment, but they do not provide sufficient coverage for adversarial safety or detailed cross-component correctness.

C. Unit tests targeting only individual prompt-template rendering logic.

Incorrect

Unit tests are valuable for testing isolated logic, but testing only prompt-template rendering does not adequately cover the **end-to-end pipeline** or attacks such as prompt injection and malformed inputs.

D. Regression tests against a stable reference set of previously known-good outputs.

Incorrect

Regression testing is useful for detecting **unexpected changes in output behavior**, but it does not directly provide targeted coverage for adversarial attacks or verify all cross-component interactions.

E. Adversarial tests using prompt-injection and malformed-input cases.

Correct

Adversarial testing directly evaluates how the system behaves under **malicious, unexpected, or malformed inputs**. For a financial-data pipeline, this helps identify safety weaknesses and potential ways attackers could manipulate the system.

Final Answer: A and E

A = Cross-component correctness

E = Safety under attack

Question: 19 CertyIQ

You are running a risk assessment on a planned Claude-based deployment and must complete the inventory steps before assessing threats against assets.
Which two steps must be completed BEFORE assessing threats against assets to estimate likelihood and impact? (Select two.) Each correct answer presents part of the solution.

A. Recommend mitigations and residual-risk acceptance for the risks that remain after analysis.
B. Recommend mitigations and residual-risk acceptance for risks that remain.
C. Enumerate the threat actors and attack vectors relevant to the deployment.
D. Document the assessment outcome with risks, mitigations, residual risk, and acceptance owners.
E. Identify the assets that the deployment touches, along with the sensitivity of each asset.

Answer: CE

Explanation:

A. Recommend mitigations and residual-risk acceptance for the risks that remain after analysis.

Incorrect

Mitigations and residual-risk acceptance are **later stages** of the risk-assessment process. You first need to identify the assets and relevant threats before determining appropriate controls.

B. Recommend mitigations and residual-risk acceptance for risks that remain.

Incorrect

This is also a **post-analysis activity**. Mitigation decisions depend on understanding the risks, their likelihood, their impact, and the controls already available.

C. Enumerate the threat actors and attack vectors relevant to the deployment.

Correct

Identifying relevant **threat actors and attack vectors** is necessary before estimating risk. Understanding who could attack the system and how they might do so helps establish the likelihood and potential impact of threats against the identified assets.

D. Document the assessment outcome with risks, mitigations, residual risk, and acceptance owners.

Incorrect

Documenting the final assessment is generally performed **after the analysis** has been completed. You need the risk findings and mitigation decisions before producing the final assessment record.

E. Identify the assets that the deployment touches, along with the sensitivity of each asset.

Correct

Asset identification is a foundational step. Knowing **which assets are involved and how sensitive they are** provides the basis for evaluating the potential impact if those assets are compromised.

Final Answer: C and E

C = Identify relevant threats and attack vectors

E = Identify affected assets and their sensitivity

Question: 20 CertyIQ

A senior architect is managing stakeholder expectations for a Claude-based reporting assistant midway through development. Stakeholders have escalating concerns about response latency.
Which two actions most directly address stakeholder expectation alignment in this situation? (Select two.)

A. Replace the current Claude model with a third-party model that may offer lower latency without evaluation.

B. Pause all development and reallocate engineering resources entirely to latency optimization.

C. Present measured p50 and p95 latency baselines against the agreed SLA thresholds so stakeholders have accurate data.

D. Revise the SLA definition collaboratively with stakeholders if current targets are not achievable given production constraints.

E. Communicate that latency concerns are a known LLM limitation and outside the architecture team's control.

Answer: CD

Explanation:

A. Replace the current Claude model with a third-party model that may offer lower latency without evaluation.

Incorrect

Replacing the model without proper evaluation does not address stakeholder alignment. It could introduce **new quality, security, compatibility, or performance risks**. Model changes should be based on measured requirements and controlled evaluation.

B. Pause all development and reallocate engineering resources entirely to latency optimization.

Incorrect

This is a broad project-management decision rather than a direct stakeholder-alignment action. It may also unnecessarily disrupt other development priorities without first establishing the actual performance gap.

C. Present measured p50 and p95 latency baselines against the agreed SLA thresholds so stakeholders have accurate data.

Correct

Providing **objective performance measurements** gives stakeholders a clear understanding of the current state. Comparing p50 and p95 latency with the agreed SLA helps distinguish actual performance gaps from perception and supports informed decisions.

D. Revise the SLA definition collaboratively with stakeholders if current targets are not achievable given production constraints.

Correct

If the original SLA is unrealistic given validated production constraints, the appropriate approach is to **review and revise it collaboratively** with stakeholders. This creates shared expectations rather than silently accepting an unachievable target.

E. Communicate that latency concerns are a known LLM limitation and outside the architecture team's control.

Incorrect

This approach dismisses stakeholder concerns instead of addressing them. Architecture teams should provide **measured evidence, options, and trade-offs** rather than treating performance as completely outside their responsibility.

Final Answer: C and D

C = Establish objective latency baselines against the SLA

D = Collaboratively revise the SLA when justified by production constraints

Question: 21 CertyIQ

A Claude architect is designing a HIPAA-compliant pipeline that processes patient records.
Which two design decisions directly support HIPAA compliance requirements? (Select two.)

A. Setting max_tokens to a low value to minimize the volume of text generated per request.

B. Selecting the highest-capability Claude model to maximize diagnostic accuracy.

C. Enforcing role-based access controls so that PH is retrievable only by authorized personnel.

D. Ensuring patient data is never included in training feedback loops sent to the model provider without a BAA in place.

E. Using streaming responses to reduce perceived latency for clinical users.

Answer: CD

Explanation:

A. Setting max_tokens to a low value to minimize the volume of text generated per request.

Incorrect

Reducing the maximum number of generated tokens can help control **cost and output length**, but it does not directly address HIPAA requirements such as access control, protection of protected health information, or appropriate contractual safeguards.

B. Selecting the highest-capability Claude model to maximize diagnostic accuracy.

Incorrect

Model capability and HIPAA compliance are separate concerns. Choosing a more capable model does not by itself provide the **privacy, access-control, contractual, or data-handling protections** required for compliant processing.

C. Enforcing role-based access controls so that PHI is retrievable only by authorized personnel.

Correct

Role-based access control (RBAC) limits access to protected health information (**PHI**) based on authorized roles. Restricting PHI access to appropriate personnel supports the principle of controlled access required when handling sensitive healthcare information.

D. Ensuring patient data is never included in training feedback loops sent to the model provider without a BAA in place.

Correct

Patient information requires appropriate **privacy and contractual safeguards** when processed by an external service provider. Ensuring PHI is not improperly used in provider training or feedback processes, and having the appropriate **Business Associate Agreement (BAA)** where required, directly supports HIPAA compliance.

E. Using streaming responses to reduce perceived latency for clinical users.

Incorrect

Streaming can improve the **user experience and perceived response speed**, but it does not directly establish

HIPAA privacy or security compliance.

Final Answer: C and D

C = Enforce role-based access to PHI

D = Apply appropriate PHI data-handling and BAA safeguards

Question: 22 CertyIQ

You are preparing an operational runbook for a Claude-based service.
Which content is essential to include in the runbook?

A. Dashboard and log references only, without alert definitions, triage steps, escalation paths, or rollback procedures for the on-call engineer to act on.

B. Common alerts and their triage steps, escalation paths, rollback procedures, and references to the relevant dashboards and logs.

C. Alert definitions and triage steps only, without escalation paths, rollback procedures, or references to dashboards and logs for on-call use.

D. Escalation paths and rollback procedures only, without alert definitions, triage steps, or dashboard references to guide initial incident response.

Answer: B

Explanation:

A. Dashboard and log references only, without alert definitions, triage steps, escalation paths, or rollback procedures for the on-call engineer to act on.

Incorrect

Dashboards and logs are useful, but references alone do not tell the on-call engineer **what the alert means, how to investigate it, who to contact, or how to recover the service**.

B. Common alerts and their triage steps, escalation paths, rollback procedures, and references to the relevant dashboards and logs.

Correct

A strong operational runbook should provide actionable guidance for incident response. It should explain **common alerts, initial triage, escalation procedures, rollback or recovery steps, and where to find the relevant monitoring information**.

C. Alert definitions and triage steps only, without escalation paths, rollback procedures, or references to dashboards and logs for on-call use.

Incorrect

Alert definitions and triage are important, but they are incomplete without **escalation paths, recovery procedures, and monitoring references**.

D. Escalation paths and rollback procedures only, without alert definitions, triage steps, or dashboard references to guide initial incident response.

Incorrect

Rollback and escalation procedures are valuable, but the on-call engineer also needs to know **how to**

recognize and investigate the incident before escalating or rolling back.

Final Answer: B. Common alerts, triage steps, escalation paths, rollback procedures, and dashboard/log references.

Question: 23 CertyIQ

A technical team is cataloguing risks specific to Claude's use in a document-grounded Q & A system.
Which two items represent failure modes intrinsic to LLM-based systems rather than generic software defects? (Select two.)

A. An expired TLS certificate blocks outbound API calls to Claude.
B. A database connection timeout causes retrieval to return an empty result set.
C. The model refuses a legitimate query because surface features trigger an overly broad safety pattern.
D. A misconfigured load balancer routes requests to a deprecated API version.
E. The model generates a plausible-sounding answer unsupported by any retrieved document.

Answer: CE

Explanation:

A. An expired TLS certificate blocks outbound API calls to Claude.

Incorrect

An expired TLS certificate is a **general infrastructure and security configuration problem**. It can affect many types of applications and is not specific to LLM behavior.

B. A database connection timeout causes retrieval to return an empty result set.

Incorrect

A database connection timeout is a **generic integration or infrastructure failure**. It is not an intrinsic failure mode of the language model itself.

C. The model refuses a legitimate query because surface features trigger an overly broad safety pattern.

Correct

This is an LLM-specific failure mode. Safety systems can sometimes produce **over-refusals**, where a legitimate request is incorrectly classified as unsafe because of particular words or patterns in the input.

D. A misconfigured load balancer routes requests to a deprecated API version.

Incorrect

This is a **deployment and infrastructure configuration issue**, not an intrinsic LLM failure mode.

E. The model generates a plausible-sounding answer unsupported by any retrieved document.

Correct

This is a classic **hallucination/grounding failure**. An LLM can generate an answer that sounds convincing even when the available source documents do not support the claim. This is particularly important in document-grounded Q&A systems.

Final Answer: C and E

C = Over-refusal of legitimate requests

E = Plausible but unsupported generated answers

Question: 24 CertyIQ

You are rolling out monitoring for a Claude-based deployment and must complete the specification steps efore instrumenting the deployment.
Which two steps must be completed BEFORE instrumenting the deployment to emit metrics and traces? (Select two.)
Each correct answer presents part of the solution.

A. Define the metrics and the slices the deployment will monitor across normal and adversarial traffic.
B. Tune the alert thresholds based on observed normal-state distributions to reduce false positives.
C. Define the service-level objectives (SLOs) and the error budgets the deployment will be held to.
D. Build the dashboards that surface metrics across slices at the cadence the team operates on.
E. Document the dashboards, alerts, and runbooks for the on-call rotation that will respond.

Answer: AC

Explanation:

A. Define the metrics and the slices the deployment will monitor across normal and adversarial traffic.

Correct

Before instrumentation, you need to determine **what you are going to measure**. Defining the metrics and relevant slices establishes the observability requirements and ensures the deployment collects meaningful data for both normal and adversarial traffic.

B. Tune the alert thresholds based on observed normal-state distributions to reduce false positives.

Incorrect

Threshold tuning requires **observed operational data**. That data generally becomes available only after instrumentation has been implemented and the system has produced baseline measurements.

C. Define the service-level objectives (SLOs) and the error budgets the deployment will be held to.

Correct

SLOs establish the **target level of service performance and reliability**. Defining them before instrumentation ensures the metrics and telemetry collected can be evaluated against meaningful objectives and error budgets.

D. Build the dashboards that surface metrics across slices at the cadence the team operates on.

Incorrect

Dashboards depend on the **metrics and telemetry being available**. While dashboard requirements can be planned early, building the operational dashboards is normally part of the implementation after the monitoring specifications have been defined.

E. Document the dashboards, alerts, and runbooks for the on-call rotation that will respond.

Incorrect

Runbooks and operational documentation are important, but they should be developed after the **monitoring requirements, instrumentation, dashboards, and alerting behavior** have been established.

Final Answer: A and C

A = Define what to measure and how to slice the data

C = Define SLOs and error budgets

Question: 25

CertyIQ

A document analysis service processes legal filings averaging 80,000 tokens each. Each filing is queried by attorneys an average of 14 times during a case. The current architecture sends the full filing on every query. The CFO has asked you to reduce per-query costs while preserving response quality. The security officer requires that filing contents not be stored outside Fabrikam's tenancy.
Which optimization approach should you recommend?

A. Summarize each filing once at intake and run all subsequent queries against the summary.
B. Cache the filing as the prompt prefix for reuse across the 14 queries per case.
C. Index filings in a vector store and retrieve only the relevant passages per query.
D. Move the workload to a smaller Claude model to reduce the per-token cost paid.

Answer: B

Explanation:

A. Summarize each filing once at intake and run all subsequent queries against the summary.

Incorrect

Summarizing the filing once can reduce the amount of context used later, but it may **discard important legal details** needed for subsequent attorney questions. For legal filings, losing precise language or specific clauses can reduce response quality.

B. Cache the filing as the prompt prefix for reuse across the 14 queries per case.

Correct

Caching the repeated filing content as a **prompt prefix** can reduce the cost associated with repeatedly processing the same large context. Since the same 80,000-token filing is reused across approximately 14 queries, caching is particularly valuable. The implementation can also be designed to keep the filing within **Fabrikam's controlled environment and approved data-handling boundaries**.

C. Index filings in a vector store and retrieve only the relevant passages per query.

Incorrect

Retrieval can reduce the amount of context sent for each query, but it requires storing and indexing the filing content in a vector store. Given the explicit requirement that filing contents **not be stored outside Fabrikam's tenancy**, an externally hosted vector store would be unsuitable unless it is explicitly within the required tenancy and security boundary.

D. Move the workload to a smaller Claude model to reduce the per-token cost paid.

Incorrect

A smaller model may reduce cost, but it could also affect **response quality**, especially for complex legal-document analysis. The requirement specifically calls for preserving quality, so reducing model capability is not the most direct optimization.

Final Answer: B. Cache the filing as the prompt prefix for reuse across the 14 queries per case.

Question: 26 CertyIQ

When communicating an architectural decision to a security and compliance reviewer, which content set is most aligned with that audience's primary concerns?

A. Feature delivery schedule, roadmap dependencies, and scope boundaries for the product manager.
B. Implementation timeline, component interfaces, and deployment sequence for the engineering team.
C. Threat model, control mappings, residual-risk acceptance criteria, and audit traceability.
D. Decision rationale, business outcomes, and high-level risk summary for executive review.

Answer: C

Explanation:

A. Feature delivery schedule, roadmap dependencies, and scope boundaries for the product manager.

Incorrect

This information is primarily relevant to a **product manager**. While delivery timelines and scope can matter to security teams, they do not directly address the reviewer's main concerns around security controls, threats, compliance, and auditability.

B. Implementation timeline, component interfaces, and deployment sequence for the engineering team.

Incorrect

These details are mainly intended for the **engineering implementation team**. They explain how the system will be built and deployed but do not provide sufficient evidence about security risks and compliance controls.

C. Threat model, control mappings, residual-risk acceptance criteria, and audit traceability.

Correct

This content directly addresses the primary concerns of **security and compliance reviewers**. They need to understand the threats being considered, which controls mitigate those threats, what residual risks remain, who accepts those risks, and how the decisions can be demonstrated during an audit.

D. Decision rationale, business outcomes, and high-level risk summary for executive review.

Incorrect

These elements are more appropriate for an **executive audience**. Executives generally need the decision, business value, and high-level risks rather than detailed control mappings and audit evidence.

Final Answer: C. Threat model, control mappings, residual-risk acceptance criteria, and audit traceability.

Question: 27

CertyIQ

You are integrating Claude Code into a workflow that runs against a production database.
Which guardrail design most directly preserves safety on data-modifying operations?

A. Allow Claude Code to write directly to the production database without subagent scoping, read-only credential defaults, or human confirmation gates on data-modifying operations.

B. Configure the database MCP server with a fully privileged credential that can perform any read or write operation, and allow all operations to proceed without explicit human confirmation.

C. Disable all logging and auditing on database operations through the MCP server to reduce alert noise, removing the observability needed to detect unintended data modifications.

D. Configure the database MCP server with a read-only credential by default, restrict the subagent's tool list to read-only operations, and require explicit human confirmation on any operation that would modify data.

Answer: D

Explanation:

A. Allow Claude Code to write directly to the production database without subagent scoping, read-only credential defaults, or human confirmation gates on data-modifying operations.

Incorrect

This design provides excessive privileges and removes important safety controls. A production database should not be exposed to unrestricted automated write operations because an unintended action could **modify or delete critical data**.

B. Configure the database MCP server with a fully privileged credential that can perform any read or write operation, and allow all operations to proceed without explicit human confirmation.

Incorrect

A fully privileged credential violates the **principle of least privilege**. Removing confirmation for write operations also eliminates an important human control over potentially irreversible changes.

C. Disable all logging and auditing on database operations through the MCP server to reduce alert noise, removing the observability needed to detect unintended data modifications.

Incorrect

Disabling logging removes valuable **auditability and observability**. Production database operations should generally be traceable so unexpected or unauthorized changes can be investigated.

D. Configure the database MCP server with a read-only credential by default, restrict the subagent's tool list to read-only operations, and require explicit human confirmation on any operation that would modify data.

Correct

This provides **defense in depth**. Read-only credentials establish a safe default, tool scoping limits what the subagent can access, and explicit human confirmation creates an additional control before potentially destructive or consequential operations are performed.

Final Answer: D. Use read-only defaults, restrict tool permissions, and require human confirmation for data modifications.

Question: 28 CertyIQ

You are identifying signals that a deployment should re-enter design rather than continue iterating in place. Which signal most directly indicates the need for a new design cycle?

A. A runbook step requires a clarification edit to improve on-call guidance accuracy, which can be handled as a documentation update without changes to component responsibilities or core contracts.

B. A dashboard alert threshold needs a small numerical adjustment to reduce false-positive noise, which can be handled as an operational configuration change without a new design cycle.

C. A minor copy edit is requested in a customer-facing string within the existing Ul, which can be handled as a localized content change without altering component responsibilities or contracts.

D. The system's current architecture cannot meet the new requirements without changes to component responsibilities or core contracts.

Answer: D

Explanation:

A. A runbook step requires a clarification edit to improve on-call guidance accuracy, which can be handled as a documentation update without changes to component responsibilities or core contracts.

Incorrect

This is a **documentation-level change**. It does not alter the system's architecture, component responsibilities, or contracts, so a new design cycle is unnecessary.

B. A dashboard alert threshold needs a small numerical adjustment to reduce false-positive noise, which can be handled as an operational configuration change without a new design cycle.

Incorrect

A small alert-threshold adjustment is an **operational tuning change**. It can be made without revisiting the underlying architecture.

C. A minor copy edit is requested in a customer-facing string within the existing UI, which can be handled as a localized content change without altering component responsibilities or contracts.

Incorrect

A copy change is a **localized content modification** and does not require architectural redesign when the existing components and contracts remain unchanged.

D. The system's current architecture cannot meet the new requirements without changes to component responsibilities or core contracts.

Correct

This is the clearest signal that the system needs to **re-enter the design cycle**. Changes to component responsibilities or core contracts affect fundamental architectural decisions and should be evaluated through a new design process rather than handled as routine iteration.

Final Answer: D. The current architecture cannot meet the new requirements without changing component responsibilities or core contracts.

Question: 29 CertyIQ

You are reviewing a peer's Claude Code permission rules for an enterprise rollout. The rules grant unrestricted Bash access to all projects across all developers.
Which response is most appropriate?

A. Add unrestricted access to additional tool categories as well, so that Bash is not asymmetrically more permissive than other tools, expanding the attack surface further in the name of consistency.

B. Approve the unrestricted Bash access as written on the grounds that narrowing the rules would add nfiguration complexity, accepting the full attack surface for all engineers across all projects.

C. Replace unrestricted Bash with narrowly scoped tool patterns that allow only the specific commands the workflows require, and add explicit deny rules for sensitive operations.

D. Disable all permission rules for the enterprise rollout so every command across every project runs without any tool-pattern scoping or explicit deny rules for sensitive operations.

Answer: C

Explanation:

A. Add unrestricted access to additional tool categories as well, so that Bash is not asymmetrically more permissive than other tools, expanding the attack surface further in the name of consistency.

Incorrect

Expanding unrestricted access does not solve the security problem. It would increase the **attack surface** and give developers broader capabilities than their workflows require.

B. Approve the unrestricted Bash access as written on the grounds that narrowing the rules would add configuration complexity, accepting the full attack surface for all engineers across all projects.

Incorrect

Enterprise permissions should follow the **principle of least privilege**. Configuration complexity is not a sufficient reason to accept unrestricted access to potentially powerful commands.

C. Replace unrestricted Bash with narrowly scoped tool patterns that allow only the specific commands the workflows require, and add explicit deny rules for sensitive operations.

Correct

This is the safest approach. Narrowly scoped permissions ensure Claude Code can perform the **required operations without unnecessary privileges**. Explicit deny rules provide an additional layer of protection for sensitive commands and operations.

D. Disable all permission rules for the enterprise rollout so every command across every project runs without any tool-pattern scoping or explicit deny rules for sensitive operations.

Incorrect

Disabling permissions entirely removes the security boundary and creates an unnecessarily large **attack surface**. Enterprise deployments require controlled and auditable access.

Final Answer: C. Use narrowly scoped tool patterns and explicit deny rules for sensitive operations.

Question: 30 CertyIQ

A solutions architect is analyzing stakeholder feedback collected after the first quarter of a Claude-powered procurement automation deployment. The feedback includes four statements:
(1) "Our procurement team is processing 3x more purchase orders per analyst per day."

(2) "We have eliminated the manual data entry role entirely and redeployed those staff to vendor relationship management."
(3) "The API integration costs are running 40% over the projected per-transaction budget."
(4) "Response latency during end-of-month batch runs is averaging 11 seconds, against our committed 5-second SLA."
Which of the following correctly identifies the primary business value pillar each stakeholder statement represents?

A. Statement 1: Efficiency; Statement 2: Transformation; Statement 3: Solution Cost; Statement 4:Performance SLA

B. Statement 1: Productivity; Statement 2: Efficiency; Statement 3: Solution Cost; Statement 4:Performance SLA

C. Statement 1: Transformation; Statement 2: Productivity; Statement 3: Solution Cost; Statement 4:Efficiency

D. Statement 1: Efficiency; Statement 2: Productivity; Statement 3: Performance SLA; Statement 4:Solution Cost

Answer: A

Explanation:

A. Statement 1: Efficiency; Statement 2: Transformation; Statement 3: Solution Cost; Statement 4: Performance SLA

Correct

Statement 1 represents **Efficiency** because the team is processing significantly more purchase orders per analyst, demonstrating improved operational efficiency.

Statement 2 represents **Transformation** because the workflow has changed the way work is performed, eliminating a manual role and redeploying employees to a higher-value activity.

Statement 3 represents **Solution Cost** because it directly concerns the actual cost of operating the API integration compared with the planned budget.

Statement 4 represents **Performance SLA** because the observed 11-second latency is being compared directly against the committed 5-second SLA.

B. Statement 1: Productivity; Statement 2: Efficiency; Statement 3: Solution Cost; Statement 4: Performance SLA

Incorrect

Although Statement 3 and Statement 4 are correctly classified, Statement 2 describes a broader **organizational/workflow transformation**, not merely an efficiency improvement. The elimination of manual data entry and redeployment of staff represents a change in how the organization operates.

C. Statement 1: Transformation; Statement 2: Productivity; Statement 3: Solution Cost; Statement 4: Efficiency

Incorrect

Statement 1 is primarily about **efficiency**, since it measures purchase orders processed per analyst. Statement 2 represents transformation, while Statement 4 clearly concerns an SLA rather than general efficiency.

D. Statement 1: Efficiency; Statement 2: Productivity; Statement 3: Performance SLA; Statement 4: Solution Cost

Incorrect

This option reverses the classifications for Statements 3 and 4. The **40% cost overrun** is a Solution Cost issue, while the **11-second response time versus the 5-second SLA** is a Performance SLA issue.

Final Answer: A

Statement 1 = Efficiency

Statement 2 = Transformation

Statement 3 = Solution Cost

Statement 4 = Performance SLA

Question: 31 CertyIQ

An operations engineer reports that a Claude-based pipeline began returning malformed JSON responses after a scheduled maintenance window, causing downstream processing failures.
Which two investigative steps most directly isolate the root cause? (Select two.)

A. Clear the prompt cache and resubmit all pending requests to eliminate stale cached prefixes.

B. Compare the current system prompt and output schema configuration against the last known good version from before the maintenance window.

C. Switch to a different Claude model tier to rule out provider-side changes as a contributing factor.

D. Increase the max_tokens limit to determine whether output truncation is causing incomplete JSON structures.

E. Replay a set of premaintenance requests against the current configuration and inspect the raw model output before downstream parsing.

Answer: BE

Explanation:

A. Clear the prompt cache and resubmit all pending requests to eliminate stale cached prefixes.

Incorrect

There is no evidence that stale cached prefixes caused the problem. Clearing the cache before establishing a baseline could introduce unnecessary changes and make the investigation harder to isolate.

B. Compare the current system prompt and output schema configuration against the last known good version from before the maintenance window.

Correct

The problem started immediately after a maintenance window, so comparing the **current configuration with the last known good configuration** is an effective way to identify changes that may have introduced the malformed JSON behavior.

C. Switch to a different Claude model tier to rule out provider-side changes as a contributing factor.

Incorrect

Changing the model introduces another variable into the investigation. The existing configuration should first be examined to determine whether a **maintenance-related configuration change** caused the issue.

D. Increase the max_tokens limit to determine whether output truncation is causing incomplete JSON

structures.

Incorrect

Output truncation can cause malformed JSON, but there is no evidence that token limits are the cause here. Increasing max_tokens would be a **configuration change before the underlying cause is established**.

E. Replay a set of premaintenance requests against the current configuration and inspect the raw model output before downstream parsing.

Correct

Replaying known premaintenance requests provides a controlled way to compare behavior. Inspecting the **raw model output before downstream parsing** helps determine whether Claude is producing malformed JSON or whether the problem occurs later in the pipeline.

Final Answer: B and E

B = Compare current and last known-good configuration

E = Replay known requests and inspect raw output before parsing

Question: 32

CertyIQ

You are compiling a diagnostic toolkit for Claude Code operational issues.
Which two diagnostic actions belong in the toolkit? (Select two.)
Each correct answer presents a complete solution.

A. Increase the model sampling temperature so that intermittent issues surface more frequently for analysis.

B. File a support ticket with vendor support before any local reproduction or evidence collection.

C. Reproduce the issue with a minimal reproduction case that isolates one variable at a time.

D. Roll back to the previous Claude Code version immediately to confirm whether the issue is version specific.

E. List the configured Model Context Protocol (MCP) servers and inspect server status to identify connection failures.

Answer: CE

Explanation:

A. Increase the model sampling temperature so that intermittent issues surface more frequently for analysis.

Incorrect

Changing the sampling temperature introduces another variable and can make the system's behavior less consistent. It is not a reliable first-line diagnostic technique for isolating Claude Code operational issues.

B. File a support ticket with vendor support before any local reproduction or evidence collection.

Incorrect

Support escalation can be appropriate when internal investigation is insufficient, but you should first **reproduce the issue and collect relevant evidence** whenever possible. This gives the support team useful diagnostic information.

C. Reproduce the issue with a minimal reproduction case that isolates one variable at a time.

Correct

A **minimal reproduction case** is a fundamental troubleshooting technique. By reducing the workflow and changing one variable at a time, you can determine which component or configuration is responsible for the failure.

D. Roll back to the previous Claude Code version immediately to confirm whether the issue is version specific.

Incorrect

An immediate rollback changes the environment before the issue has been properly characterized. Version comparison can be useful later, but first you should **collect evidence and isolate the problem**.

E. List the configured Model Context Protocol (MCP) servers and inspect server status to identify connection failures.

Correct

MCP servers are important dependencies in Claude Code workflows. Checking the configured servers and their status can quickly identify **connection, availability, or configuration problems** that may be causing the operational issue.

Final Answer: C and E

C = Reproduce the issue using a minimal reproduction case.

E = Inspect configured MCP servers and their connection status.

Question: 33

CertyIQ

You are assessing data-exfiltration risk in a Claude-based assistant that has tools for both internal-document retrieval and outbound HTTP calls.
Which scenario most directly indicates a data-exfiltration risk?

A. The outbound HTTP tool returns a 200 response when the assistant calls an allow-listed domain to fulfil a user-initiated data-lookup request.

B. The user submits a routine question and receives a routine answer.

C. Adversarial content in a retrieved document instructs the model to call the outbound HTTP tool and send sensitive content to an attacker-controlled URL.

D. The internal-document retrieval tool returns a document that the user is authorized to view.

Answer: C

Explanation:

A. The outbound HTTP tool returns a 200 response when the assistant calls an allow-listed domain to fulfil a user-initiated data-lookup request.

Incorrect

This describes a normal, authorized tool interaction. The destination is **allow-listed**, and the request was initiated by the user for a legitimate purpose. There is no indication that sensitive information is being sent to an unauthorized destination.

B. The user submits a routine question and receives a routine answer.

Incorrect

A routine question producing a routine answer does not indicate data exfiltration. There is no evidence of **unauthorized data access or transmission**.

C. Adversarial content in a retrieved document instructs the model to call the outbound HTTP tool and send sensitive content to an attacker-controlled URL.

Correct

This is a direct **data-exfiltration scenario**. The retrieved document contains adversarial instructions attempting to manipulate the model into sending sensitive information to an attacker-controlled destination. This is a classic example of **indirect prompt injection combined with an outbound tool**, creating a serious security risk.

D. The internal-document retrieval tool returns a document that the user is authorized to view.

Incorrect

The user is authorized to access the document, so the retrieval itself does not indicate unauthorized disclosure or exfiltration.

Final Answer: C

C = Adversarial retrieved content attempts to send sensitive data to an attacker-controlled URL.

Question: 34 CertyIQ

After a prompt-template update, several previously passing test cases now produce unexpected outputs. Which test type is specifically designed to detect this category of failure?

A. Integration tests that validate cross-component pipeline behavior.
B. Adversarial tests that probe for prompt-injection vulnerabilities.
C. Regression tests scored against a stable reference set of known-good behavior.
D. Smoke tests that confirm high-level system availability after the change.

Answer: C

Explanation:

A. Integration tests that validate cross-component pipeline behavior.

Incorrect

Integration tests focus on whether multiple components work correctly **together**. They are useful for detecting interface and integration problems, but this scenario specifically concerns a change causing previously passing cases to behave differently.

B. Adversarial tests that probe for prompt-injection vulnerabilities.

Incorrect

Adversarial tests are designed to identify **security weaknesses and attack behaviors**, such as prompt injection. They are not specifically intended to detect regressions caused by a prompt-template change.

C. Regression tests scored against a stable reference set of known-good behavior.

Correct

Regression testing compares the current behavior against a **stable set of previously validated results**. If a prompt-template update causes previously passing test cases to produce unexpected outputs, regression tests can identify those unintended changes.

D. Smoke tests that confirm high-level system availability after the change.

Incorrect

Smoke tests primarily verify that the system's **basic functionality and availability** remain intact after a change. They generally do not provide detailed comparison against previously known-good outputs.

Final Answer: C

C = Regression tests against a stable reference set of known-good behavior.

Question: 35

CertyIQ

You are identifying the highest-impact optimization for a deployment whose token cost is dominated by a long, repeated system prompt and a large retrieved context per request.
Which optimization most directly targets the dominant cost driver?

A. Increase retrieval depth on every request to maximize recall, worsening the dominant cost driver by adding more retrieved tokens per request rather than reducing them.

B. Add additional repeated content to the system prompt to give the model more guidance.

C. Move the long, repeated system prompt into a cacheable prefix and trim retrieved context to the spans relevant to each query.

D. Switch every request to the heaviest available model to maximize output quality, accepting that higher per-request inference cost compounds rather than addresses the dominant cost driver.

Answer: C

Explanation:

A. Increase retrieval depth on every request to maximize recall, worsening the dominant cost driver by adding more retrieved tokens per request rather than reducing them.

Incorrect

Increasing retrieval depth adds even more tokens to each request. Since the current cost is already dominated by **large retrieved context**, this would increase the primary cost driver rather than optimize it.

B. Add additional repeated content to the system prompt to give the model more guidance.

Incorrect

Adding more repeated content makes the system prompt larger and increases token usage. It directly works against the goal of reducing the dominant prompt-related cost.

C. Move the long, repeated system prompt into a cacheable prefix and trim retrieved context to the spans relevant to each query.

Correct

This approach directly addresses **both major cost drivers**. Caching the repeated system prompt reduces the cost of repeatedly processing identical prefix content, while trimming retrieval to only relevant passages

reduces the number of context tokens processed for each request.

D. Switch every request to the heaviest available model to maximize output quality, accepting that higher per-request inference cost compounds rather than addresses the dominant cost driver.

Incorrect

Using a heavier model generally increases **inference cost and resource consumption**. It does not address the repeated system prompt or excessive retrieved context that are causing the current cost problem.

Final Answer: C

C = Cache the repeated prompt prefix and trim retrieved context to query-relevant content.

Question: 36 CertyIQ

You are designing a feedback session for a deployment in flight.
Which structure best supports productive stakeholder feedback?

A. Hold an open-ended meeting with no pre-distributed agenda or artifacts, and rely on participants' memory to carry decisions and follow-up owners forward.

B. Define a focused agenda, share the artifacts in advance, capture decisions and follow-ups in writing, and confirm action owners and dates.

C. Distribute artifacts at the session start rather than in advance, so stakeholders review materials in real timewithout preparation before the discussion begins.

D. End the session without recording decisions, follow-up items, action owners, or dates, relying on participant memory to carry the session's outcomes forward.

Answer: B

Explanation:

A. Hold an open-ended meeting with no pre-distributed agenda or artifacts, and rely on participants' memory to carry decisions and follow-up owners forward.

Incorrect

An unstructured meeting makes it difficult to keep the discussion focused and can lead to **unclear decisions and missing follow-up actions**. Relying on memory also increases the chance that important commitments will be lost.

B. Define a focused agenda, share the artifacts in advance, capture decisions and follow-ups in writing, and confirm action owners and dates.

Correct

This creates a **structured and accountable feedback process**. Sharing materials beforehand gives stakeholders time to prepare, while documenting decisions, owners, and deadlines ensures that feedback turns into clear, trackable actions.

C. Distribute artifacts at the session start rather than in advance, so stakeholders review materials in real time without preparation before the discussion begins.

Incorrect

Providing materials only at the start leaves stakeholders with insufficient preparation time. This can reduce

the quality of discussion and make it harder to reach informed decisions efficiently.

D. End the session without recording decisions, follow-up items, action owners, or dates, relying on participant memory to carry the session's outcomes forward.

Incorrect

Without written decisions and assigned owners and dates, accountability becomes unclear. Effective stakeholder feedback should produce **documented, actionable outcomes**.

Final Answer: B

B = Focused agenda + advance artifacts + documented decisions + clear owners and dates.

Question: 37 CertyIQ

A loan pre-qualification assistant shows 94 percent approval recommendations that match the human underwriter decision. The fairness team has reviewed approval rate parity across protected groups and reported no significant difference. A board member has asked whether this evidence is sufficient to declare the assistant fair.
Which two Discernment-competency findings should you report? (Select two.) Each correct answer presents part of the solution.

A. Approval rate parity does not by itself assess error rate parity across protected groups.
B. Match with human underwriters does not establish freedom from underwriter-introduced bias.
C. The 94 percent match rate is sufficient evidence of fairness for the assistant's decisions.
D. The fairness team's review process likely missed at least some of the protected groups studied.
E. A larger sample is needed before any meaningful fairness claim can be made about the model.

Answer: AB

Explanation:

A. Approval rate parity does not by itself assess error rate parity across protected groups.

Correct

Equal or similar approval rates do not necessarily mean the system performs equally well across groups. A proper fairness assessment should also consider **error patterns**, such as false positives and false negatives, across protected groups.

B. Match with human underwriters does not establish freedom from underwriter-introduced bias.

Correct

A 94% match with human decisions only shows that the assistant agrees with the existing decision process. If human underwriters have **existing biases**, the model could reproduce those biases rather than eliminate them.

C. The 94 percent match rate is sufficient evidence of fairness for the assistant's decisions.

Incorrect

Agreement with human decisions measures **consistency**, not fairness. High agreement alone cannot establish that the decisions are unbiased or equitable.

D. The fairness team's review process likely missed at least some of the protected groups studied.

Incorrect

There is no evidence that the fairness team omitted protected groups. This conclusion cannot be drawn from the information provided.

E. A larger sample is needed before any meaningful fairness claim can be made about the model.

Incorrect

Sample size can affect statistical confidence, but the key issue here is that **approval-rate parity and agreement with humans are insufficient fairness measures even when the sample is large**.

Final Answer: A and B

A = Approval-rate parity does not establish error-rate parity.

B = Agreement with humans does not establish freedom from human bias.

Question: 38 CertyIQ

You are an architect supporting the iteration phase of a deployed Claude-based system.
Which activity most directly fits this phase?

A. Rebuild the entire system architecture from scratch at the start of every iteration cycle regardless of what production telemetry, evaluations, and stakeholder feedback indicate is needed.

B. Stop measuring production outcomes once the deployment has successfully launched, treating the go-live milestone as the end of the evaluation and iteration cycle.

C. Discard the evaluation framework and reference set once the deployment is in production, accepting that future iterations will have no structured basis for measuring the impact of changes.

D. Review production telemetry, sampled output evaluations, and stakeholder feedback to identify the highest-impact change for the next cycle, then plan the change against the evaluation framework.

Answer: D

Explanation:

A. Rebuild the entire system architecture from scratch at the start of every iteration cycle regardless of what production telemetry, evaluations, and stakeholder feedback indicate is needed.

Incorrect

Iteration does not mean rebuilding the entire system every cycle. Changes should be **evidence-driven**, based on production results, evaluations, and stakeholder feedback.

B. Stop measuring production outcomes once the deployment has successfully launched, treating the go-live milestone as the end of the evaluation and iteration cycle.

Incorrect

Deployment is not the end of evaluation. Production monitoring and ongoing evaluation are essential for identifying **performance issues, quality changes, and opportunities for improvement**.

C. Discard the evaluation framework and reference set once the deployment is in production, accepting that future iterations will have no structured basis for measuring the impact of changes.

Incorrect

The evaluation framework and reference set provide a **consistent baseline** for measuring whether changes

improve or degrade the system. They should be maintained throughout iteration.

D. Review production telemetry, sampled output evaluations, and stakeholder feedback to identify the highest-impact change for the next cycle, then plan the change against the evaluation framework.

Correct

This directly reflects an **evidence-driven iteration cycle**. Production telemetry, output evaluations, and stakeholder feedback reveal where improvements are most valuable. The proposed change can then be evaluated against the existing framework to measure its impact.

Final Answer: D

D = Use production telemetry, evaluations, and stakeholder feedback to identify and plan the highest-impact improvement.